

PREVENZIONE DA ATTACCHI XSS E SQLi

Gli attacchi XSS e SQLi sono causati da una cattiva gestione da parte del codice del sito web dei dati in input dell'utente:

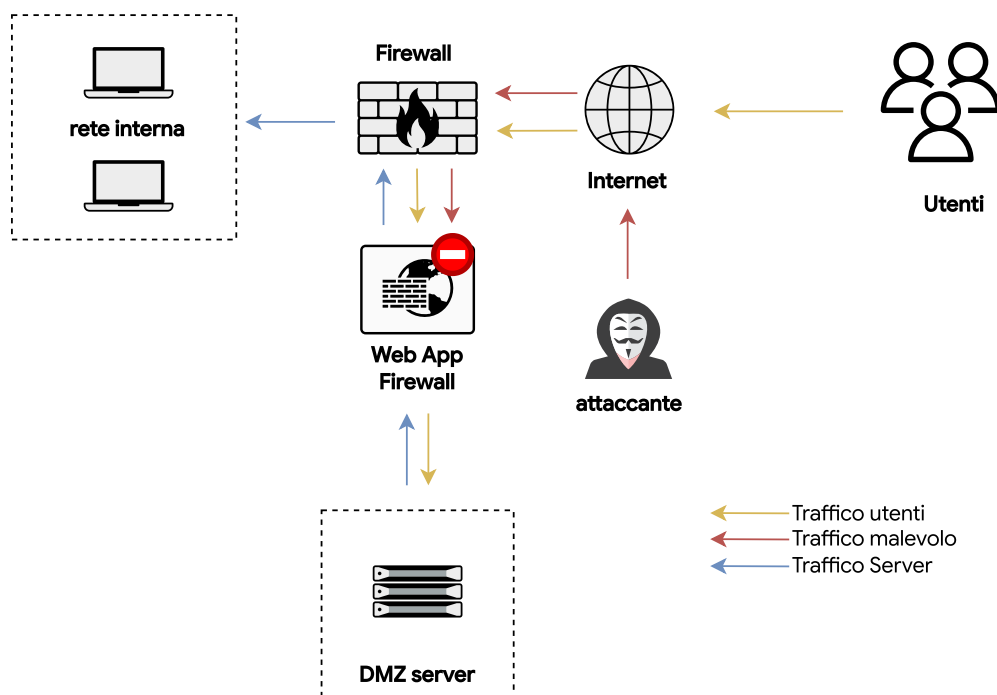
- **SQLi**: i dati inseriti dall'utente, vengono eseguiti come codice dal database, provocando una fuga di dati sensibili.
- **XSS**: i dati inseriti dall'utente sono eseguiti sul browser di un visitatore ignaro, permettendo all'attaccante di rubare cookie di sessione, credenziali o reindirizzare l'utente su siti malevoli.

Pertanto la miglior pratica di prevenzione per aggirare queste vulnerabilità risiede nel riscrivere in modo efficace il codice dei campi di input presenti sulla pagina web, implementando rigorose procedure di validazione (verificare che il dato inserito sia corretto) e sanificazione (ripulire l'input dai caratteri pericolosi), seguendo le pratiche di **secure coding**, alcuni esempi:

- **Prepared statements**: impediscono al database di vedere i dati inseriti nel campo di input come codice da eseguire.
- **Output encoding**: codifica dei caratteri pericolosi, in modo tale che non vengono interpretati come codice eseguibile dal browser.
- **Principio del privilegio minimo**: concedere all'applicativo solo i privilegi necessari quando deve comunicare con il database.

Un ulteriore strato di protezione per il sito web da attacchi di questo tipo risiede nei Web Application Firewall (WAF), un firewall che opera a livello applicativo ed esamina le richieste HTTP/HTTPS. È dotato di un database dove sono contenute le richieste malevole (Firme); se una richiesta HTTP/HTTPS dovesse contenere una di queste firme, il Web Application Firewall provvede a bloccarla.

Qui di seguito è mostrata una configurazione di rete che prevede l'implementazione di un Web Application Firewall (WAF) e come verrebbe gestito il traffico:



ANALISI DELL'IMPATTO E STRATEGIE DI PREVENZIONE CONTRO GLI ATTACCHI DDOS

Analisi dell'Evento e Impatto Economico

Un attacco DDoS (Distributed Denial of Service) della durata di soli 10 minuti, registrato ai danni del sito e-commerce, ha causato una perdita stimata di 15.000 euro. Tale dato deriva dalla media di spesa degli utenti, calcolata in circa 1.500 euro al minuto.

Oltre al danno economico immediato, è fondamentale considerare i costi indiretti e reputazionali:

- **Malcontento dell'utenza:** L'impossibilità di accedere al servizio genera frustrazione nei visitatori.
- **Perdita di vendite future:** Il disagio provocato può spingere i clienti verso piattaforme competitor, erodendo la fiducia nel brand nel lungo periodo.
- **Danno d'immagine:** Sebbene in questo caso il lasso di tempo sia stato limitato, la ricorrenza di tali eventi può compromettere seriamente la reputazione aziendale.

Considerando il forte trend di crescita di questi fenomeni, è necessaria l'implementazione di azioni preventive e modifiche strutturali per ridurre il Recovery Time Objective (RTO) e mitigare i rischi futuri.

Azioni Correttive e Preventive Suggerite

Per una difesa efficace, si consiglia un approccio multi-livello che copra aspetti volumetrici, di protocollo e applicativi.

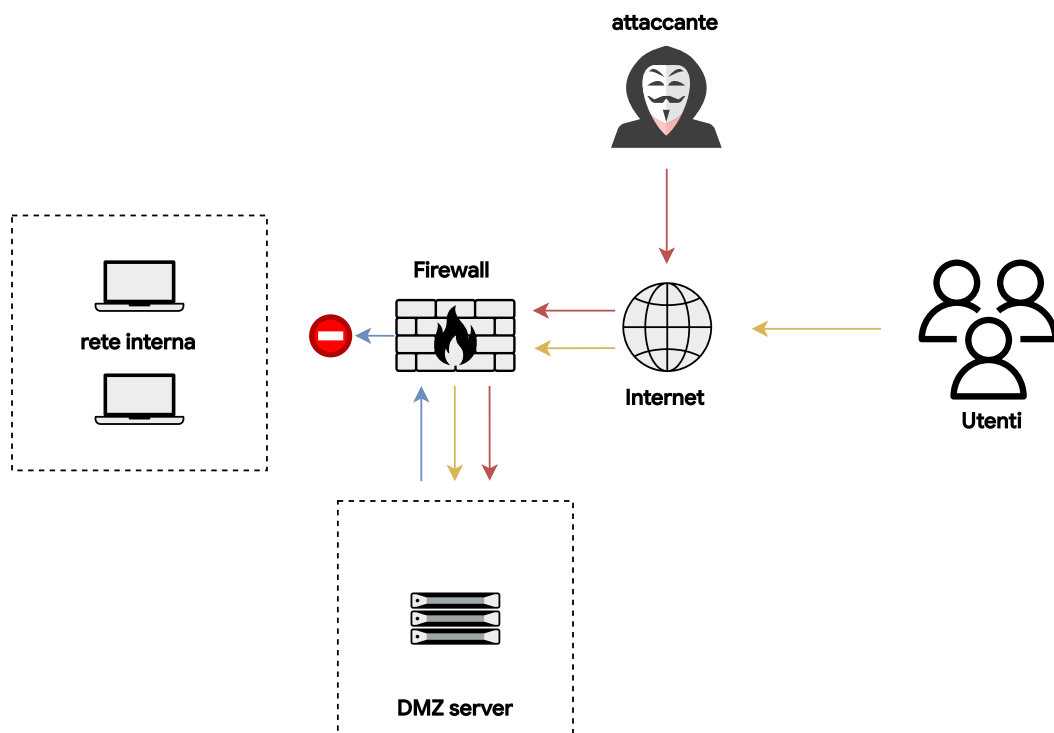
Threat intelligence	Raccolta e analisi di informazioni sulle minacce correnti e sui nuovi vettori di attacco. Con l'obiettivo di prevenire i rischi prima che si concretizzano.
Blacklisting & IP filtering	Blocco preventivo di domini e indirizzi IP noti per attività malevole, per ridurre il traffico illegittimo alla radice.
Scalabilità hardware	Potenziamento di RAM e CPU per aumentare la capacità di calcolo dei server. Per mitigare attacchi di piccola/media intensità.
Rate limiting	Limitazione del numero di richieste accettate da un singolo IP in un breve intervallo di tempo. Per contrastare i tentativi di saturazione delle risorse.
Reverse proxy & WAF	Utilizzo di servizi cloud per lo scrubbing del traffico e firewall applicativi (WAF). Filtrare il traffico prima che raggiunga il server reale.
Monitoraggio	Analisi continua dei flussi di rete per identificare picchi anomali in tempo reale, per rispondere rapidamente ad un attacco in corso.

RESPONSE

Il server, isolato in una DMZ ma con possibilità di comunicare con la rete interna dell'azienda è stato infettato da un malware, per evitare il movimento laterale del malintenzionato, ma al contempo garantire l'erogazione dei servizi, ecco come procedere:

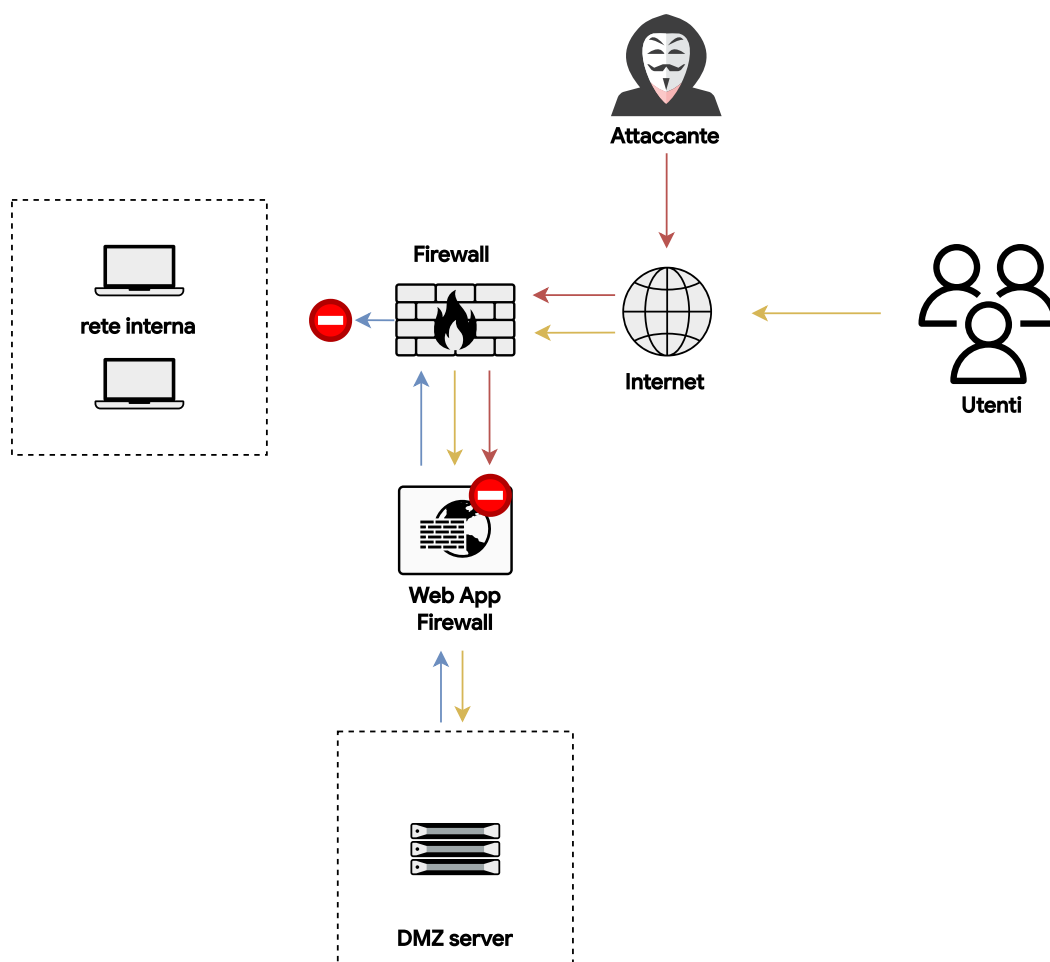
- **Contenimento minaccia:** Impostare una regola firewall di deny/drop ALL per connessioni che vanno dal server verso la rete aziendale, o nel caso in cui il server debba accedere a database nella rete aziendale, applicare il principio del privilegio minimo.
- **Eliminare la minaccia:** Una volta identificata la minaccia, si procede a ripristinare un backup del server antecedente all'infezione malware.
- **Post-incidente:** Analizzare come il malware è riuscito a raggiungere il server ed attuare le pratiche di sicurezza per impedire che l'incidente riaccada.

Durante la fase di contenimento ecco come il traffico verrebbe gestito:



CONFIGURAZIONE PREVENZIONE DA XSS E SQLi CON INTEGRAZIONE RESPONSE

Qui viene mostrata una configurazione che oltre a proteggere da vulnerabilità XSS ed SQLi, viene integrata l'eventuale response a seguito di un'infezione malware riscontrata sul server, per mettere al sicuro la rete interna dell'organizzazione.



HIGH LEVEL DESIGN

Per la protezione del business nel modo migliore da attacchi DDos, XSS, SQLi ed evitare la propagazione di malware nella rete dei dispositivi aziendali, si consiglia:

Servizio: CloudFlare Enterprise Basic

Costo stimato: 25.000€/anno

Descrizione: Servizio di reverse proxy in Cloud, garantisce protezione da attacchi DDoS, e integra un Web Application Firewall per filtrare le richieste malevole verso il server.

Servizio: CloudFlare Zero Trust

Costo stimato: 6.000€/anno per 70 utenti.

Descrizione: Protegge gli accessi back-end al server ed ai servizi fisici in ufficio, da implementare sul personale con alti privilegi.

Servizio: PacketFence (opensource) per 250 dispositivi.

Costo stimato: 1° anno 10.000€ per hardware dedicato, installazione e configurazione, a partire dal 2° anno il costo si aggirerà intorno ai 5.000€ per l'assistenza.

Descrizione: servizio di Network Access Control (NAC), verifica che i dispositivi che si collegano alla rete siano sicuri, aggiornati e non infetti da nessun malware. Nega l'accesso alla rete interna ai dispositivi che non sono appartenenti all'azienda (BYOD).

Costo totale: 41.000€ primo anno, 36.000€/anno dal secondo anno.

Ho creato la rete interna dell'azienda segmentandola in tre VLAN, il cui accesso viene regolato dal Network Access Control (NAC), una VLAN dedicata ai dispositivi della compagnia, ed una VLAN dedicata ai dispositivi dei dipendenti (BYOD), e la DMZ del server, in modo tale da impedire movimenti laterali dei malware dai dispositivi dei dipendenti verso i dispositivi aziendali.

Qui di sotto è presente un'illustrazione grafica di come avverrebbe il traffico della rete:

